

## STAGE 1

### ***Setting paths:***

```
cd /home/user01/springboot-25-log4j-structural/spring-boot-v2.5.0
```

```
R="$PWD/reports"
```

```
mkdir -p "$R"
```

```
MODULE=":spring-boot-tests:spring-boot-smoke-tests:spring-boot-smoke-test-actuator-  
log4j2"
```

```
MODULE_DIR="spring-boot-tests/spring-boot-smoke-tests/spring-boot-smoke-test-  
actuator-log4j2"
```

### ***Gradle ground truth:***

```
./gradlew ${MODULE}:dependencyInsight \  
--configuration runtimeClasspath \  
--dependency log4j-core \  
| tee "$R/gradle-log4j-core-dependency-insight.txt"
```

```
./gradlew ${MODULE}:dependencies \  
--configuration runtimeClasspath \  
| tee "$R/gradle-runtimeClasspath.txt"
```

```
grep -i "log4j-core" "$R/gradle-runtimeClasspath.txt" \  
| tee "$R/stage1-springboot-gradle-log4j-core.txt"
```

### ***Copy gradle runtimeclasspath jars:***

```
cat > "$R/copy-runtime-classpath.gradle" <<'EOF'

allprojects {

    afterEvaluate { project ->

        if (project.path == ':spring-boot-tests:spring-boot-smoke-tests:spring-boot-smoke-
test-actuator-log4j2') {

            project.tasks.register('copyRuntimeClasspath', Copy) {

                from project.configurations.runtimeClasspath

                into "${rootProject.projectDir}/reports/runtime-libs"

            }

        }

    }

}

EOF
```

```
./gradlew -I "$R/copy-runtime-classpath.gradle" ${MODULE}:copyRuntimeClasspath
```

```
find "$R/runtime-libs" -name "log4j-core-2.14.1.jar" -print \
| tee "$R/stage1-springboot-runtime-log4j-core.txt"
```

### ***Syft as SBOM tool on runtime libs:***

```
syft dir:"$R/runtime-libs" \
-o cyclonedx-json="$R/syft-runtime-libs.cdx.json"
```

```
jq -r '
.components[]?
| select(
  (.name // "" | test("log4j-core"; "i"))
  or
  (.purl // "" | test("log4j-core"; "i"))
)
| [.group, .name, .version, .purl]
| @tsv
'$R/syft-runtime-libs.cdx.json' \
| tee "$R/stage1-springboot-syft-log4j-core.tsv"
```

***Trivy as SBOM tool on runtime libs:***

```
trivy fs \
--format cyclonedx \
--output "$R/trivy-runtime-libs.cdx.json" \
"$R/runtime-libs"
```

```
jq -r '
.components[]?
| select(
  (.name // "" | test("log4j-core"; "i"))
  or
  (.purl // "" | test("log4j-core"; "i"))
)
```

```
| [.name, .version, .purl]
| @tsv
' "$R/trivy-runtime-libs.cdx.json" \
| tee "$R/stage1-springboot-trivy-log4j-core.tsv"
```

***Cdxgen from full gradle repo context:***

```
cdxgen -t java -r \
-o "$R/cdxgen-springboot-root.cdx.json" \
.

jq -r '
.components[]?
| select(
  (.name // "" | test("log4j-core"; "i"))
  or
  (.purl // "" | test("log4j-core"; "i"))
  or
  (."bom-ref" // "" | test("log4j-core"; "i"))
)
| [.group, .name, .version, .purl, ."bom-ref"]
| @tsv
' "$R/cdxgen-springboot-root.cdx.json" \
| tee "$R/stage1-springboot-cdxgen-log4j-core.tsv"
```

### ***Grype on Syft as vulnerability scan:***

```
grype sbom:"$R/syft-runtime-lib.cdx.json" \  
-o json > "$R/grype-from-syft-runtime-lib.json"
```

```
jq -r '  
.matches[]?  
| select(  
  (.artifact.name // "" | test("log4j-core"; "i"))  
  or  
  (.artifact.purl // "" | test("log4j-core"; "i"))  
)  
| [  
  .artifact.name,  
  .artifact.version,  
  .artifact.purl,  
  .vulnerability.id,  
  .vulnerability.severity  
]  
| @tsv  
' "$R/grype-from-syft-runtime-lib.json" \  
| tee "$R/stage1-springboot-grype-log4j-vulns.tsv"
```

**Trivy on Syft as vulnerability scan:**

```
trivy sbom \  
  --format json \  
  --output "$R/trivy-from-syft-runtime-libs.json" \  
  "$R/syft-runtime-libs.cdx.json"  
  
jq -r '  
  .Results[]?.Vulnerabilities[]?  
  | select(  
    (.PkgName // "" | test("log4j-core"; "i"))  
    or  
    (.PkgIdentifier.PURL // "" | test("log4j-core"; "i"))  
  )  
  | [  
    .PkgName,  
    .InstalledVersion,  
    .VulnerabilityID,  
    .Severity,  
    (.FixedVersion // "")  
  ]  
  | @tsv  
' "$R/trivy-from-syft-runtime-libs.json" \  
| tee "$R/stage1-springboot-trivy-log4j-vulns.tsv"
```